



ЛЕКЦИЯ 20

Приватность, запоминание данных и итоговая оценка надёжности ML- модели

Машинное обучение и безопасность систем · Завершающая лекция курса

НИУ ВШЭ (МИЭМ) · ОП «Информационная безопасность и технологии ИИ»

Автор: Силаев Ю. В. · Время изучения: ~70 минут



О чём эта лекция за минуту чтения

2 / 58

ЧАСТЬ 1 · ВВЕДЕНИЕ

Финал курса: две связанные половины – приватность и итоговая сборка надёжности

Вы прошли весь курс: метрики, валидацию, интерпретируемость, устойчивость, состязательные воздействия и нарушение целостности данных. Эта лекция – **сборка всего в единый взгляд на надёжность** – и добавляет последний недостающий аспект: приватность.

ПОЛОВИНА 1

Приватность и запоминание данных

Почему модель с отличными метриками может быть небезопасной: она запоминает чувствительные данные, и их можно восстановить из ответов, логов и артефактов.

ПОЛОВИНА 2

Итоговая оценка надёжности

Как собрать весь курс в один структурированный документ – reliability/security note: можно ли доверять модели, в каких пределах и при каких допущениях.



После изучения этой лекции

- объяснять, почему модель может запоминать чувствительные данные из обучающего корпуса;
- различать качество модели и безопасность обращения с данными;
- формулировать базовые меры снижения риска утечки через данные, артефакты и поведение модели;
- понимать общую идею privacy-preserving подходов и differential privacy на уровне интуиции;
- упоминать federated и split learning как подходы, ограничивающие централизацию данных, и их пределы;
- составлять итоговую структурированную оценку надёжности ML-модели (reliability note);
- формулировать границы применимости и рекомендации по безопасной эксплуатации решения.



Что нужно знать до начала

4 / 58

ЧАСТЬ 1 · ВВЕДЕНИЕ

Это итоговая лекция – она опирается на весь курс

Отдельных новых предпосылок нет: L20 собирает воедино темы всего курса.

L03

Постановка ML-задачи и режим использования

L04

Метрики качества и цена ошибок

L05

Протоколы валидации и утечки данных (data leakage)

L09

Интерпретируемость и анализ ошибок

L16

LLM в безопасности (memorization как частный случай)

L17

Устойчивость к шуму, выбросам и сдвигу данных

L18

Состязательные воздействия (evasion, threat modeling)

L19

Нарушение целостности: poisoning, backdoor, supply-chain



План лекции

5 / 58

ЧАСТЬ 1 · ВВЕДЕНИЕ

7 частей · 58 слайдов · ~70 минут изучения

1	Введение	1-5	~6 мин
2	Мотивация: точная модель, которая утекает	6-9	~5 мин
3А	Приватность и запоминание данных	10-28	~22 мин
3В	Итоговая оценка надёжности (reliability note)	29-45	~20 мин
4	Связки с практикой ИБ	46-52	~8 мин
5	Итоги	53-55	~4 мин
6	Источники для углубления	56-57	~3 мин
7	Глоссарий	58	~2 мин



ЧАСТЬ 2 · МОТИВАЦИЯ

Зачем говорить о приватности, если модель уже точная?

Модель прошла все проверки качества и устойчивости. Почему её всё ещё нельзя считать готовой к внедрению – и при чём здесь данные, на которых она училась.



Реальная ситуация из практики ИБ

ИБ-КЕЙС

Детектор подозрительного трафика на логах с персональными полями

Команда обучила классификатор сетевых событий на внутренних логах. В признаки попали **внутренние IP, имена хостов и учётных записей, фрагменты URL и user-agent**. На отложенной выборке модель показала ROC-AUC 0.98 и высокий recall по атакам – формально отличный результат, который согласовали к внедрению.

Что вскрылось позже: по объяснениям модели и сохранённым примерам аналитики смогли восстановить, какие конкретные внутренние узлы и учётные записи фигурировали в обучающих логах. Метрики качества это никак не показывали.

CIC-IDS-2018 – сквозной датасет курса. Публичный сетевой трафик: ~16 млн flow-записей за 10 дней, 80 признаков, 14 типов атак + Benign. Дальше – по имени.



Качество – необходимое, но не достаточное условие готовности модели

Метрики отвечают на вопрос «насколько часто модель права». Но перед внедрением нужен другой вопрос – **«можно ли эту модель допускать в эксплуатацию и при каких условиях»**. Это разные вопросы. Хорошая по метрикам модель может быть недопустимой: она раскрывает чувствительные данные, ведёт себя непредсказуемо при сдвиге, уязвима к атакам или применяется за пределами сценария, под который её проверяли.

На что метрики отвечают

- доля верных решений на тесте
- баланс ошибок I и II рода (из L04)
- разделимость классов (ROC-AUC)
- качество калибровки вероятностей

О чём метрики молчат

- запоминание чувствительных данных
- восстановимость данных из артефактов
- поведение за пределами сценария
- границы применимости и режим доверия



Что происходит в реальных системах, когда приватность и итоговый аудит игнорируют

ЧАСТАЯ ОШИБКА

«Если метрики хорошие, модель готова. А приватность – это про персональные данные, у нас задача не такая».

Так рассуждают, когда нет привычки отделять качество от допустимости и нет финального аудита надёжности перед внедрением.

ПОЧЕМУ ЭТО НЕВЕРНО

Без инструмента приватности и итоговой оценки в реальных системах возникает цепочка типовых провалов:

- чувствительные примеры и артефакты публикуются «для воспроизводимости» – и из них восстанавливают закрытые сведения;
- «обезличили» считают синонимом «безопасно» – хотя реидентификация остаётся возможной;
- модель внедряют без фиксации границ – и это создаёт ложное чувство надёжности, которое дороже честного «не знаем».



ЧАСТЬ 3 · БЛОК А

Приватность и запоминание данных

Сейчас разберём, как модель удерживает следы обучающих данных, по каким каналам это может утекать и какими мерами риск снижают. Это первая половина лекции.

A.1

Риски что и как
утекает

A.2

Меры чем снижают
риск

A.3

Trade-off цена
приватности

сейчас здесь ↑ A.1



Свойство обращения с данными, а не свойство качества модели

ОПРЕДЕЛЕНИЕ

Приватность ML-системы

Свойство системы не раскрывать сведения об отдельных объектах обучающих данных – ни напрямую, ни через выводимые из модели и её артефактов признаки.

Качество отвечает на вопрос «насколько модель права». Приватность отвечает на другой: **что можно узнать о людях и сущностях, чьи данные участвовали в обучении**. Эти свойства независимы – модель бывает точной и непредсказуемо «болтливой» одновременно.

Важно с самого начала: приватность – это не только про персональные данные людей. В ИБ к чувствительным относятся и служебные сведения: внутренняя топология сети, имена узлов и учётных записей, схемы реагирования. Раскрытие любого из этого – нарушение приватности системы.



Memorization: модель хранит следы конкретных обучающих примеров

ОПРЕДЕЛЕНИЕ

Запоминание (memorization)

Эффект, при котором обученная модель удерживает информацию об отдельных обучающих примерах настолько, что эти примеры (или их фрагменты) можно частично восстановить или распознать по поведению модели.

Обобщение vs запоминание. В идеале модель извлекает из данных закономерности (обобщает). Но та же ёмкость, что помогает обобщать, позволяет и запоминать отдельные точки – особенно редкие, выбросовые или многократно повторённые. Чем больше параметров и чем дольше обучение без регуляризации, тем выше риск.

Парадокс: запоминание не обязательно ухудшает метрики – на тесте такая модель может выглядеть отлично. Именно поэтому риск приватности нельзя «увидеть» через ассигасу или ROC-AUC.



Обучение на данных ≠ право на восстановление

Законность использования данных и допустимость их раскрытия – разные вопросы

Тот факт, что данные правомерно использованы для обучения, **не означает, что из готовой модели допустимо извлекать сведения об отдельных записях**. Обучение агрегирует и обобщает; восстановление конкретной строки обучающего набора – это уже раскрытие исходных данных, на которое согласия и оснований обычно нет.

Цель обучения – это про закономерности

- выявить общие признаки атак и нормы
- перенести закономерность на новые данные
- работать со статистикой по выборке в целом

Восстановление – это уже раскрытие данных

- воспроизвести конкретную обучающую запись
- узнать, был ли объект в обучении (см. сл. 16)
- извлечь чувствительное поле конкретной строки



Данные могут раскрыться через множество производных артефактов

Утечка данных (как в L05) в контексте приватности – шире, чем утечка между train и test. Раскрытие происходит и через производные артефакты, которые легко упустить из виду:

Логи и отчёты

сырые значения признаков в журналах, дашбордах, отчётах об ошибках

Опубликованные примеры

«репрезентативные» сэмплы и кейсы в документации и статьях

Embeddings

сохранённые векторные представления – это тоже данные (сл. 15)

Артефакты обучения

веса, чекпоинты, кэши признаков, промежуточные представления

Поведение модели

ответы, уверенности, объяснения – из них восстанавливают вход

Метаданные

имена файлов, идентификаторы, временные метки в составе признаков



Embeddings и промежуточные представления

Сохранённый вектор – это тоже данные, а не «обезличенные числа»

Эмбеddинг – это плотное векторное представление объекта (записи лога, текста инцидента, файла). Кажется, что «просто числа» безопасны. На деле **эмбеddинг сохраняет достаточно информации, чтобы по нему частично восстановить исходный объект или сопоставить его с конкретной записью**. Хранилище эмбеddингов нужно защищать как хранилище исходных данных.

Инверсия

по вектору приближённо реконструируют исходный вход (embedding inversion)

Связывание

один и тот же объект узнаётся в разных наборах по близости векторов

Атрибуты

из вектора вытягивают чувствительные свойства, не заданные явно

Практический вывод: эмбеddинги, индексы векторного поиска и кэши представлений попадают в reliability note наравне с исходным датасетом – у них тот же режим доступа и хранения.



Вопрос атакующего: «был ли этот объект в обучающем наборе?»

ОПРЕДЕЛЕНИЕ

Membership inference

Определение принадлежности конкретного объекта к обучающему набору модели по её наблюдаемому поведению – без доступа к самим обучающим данным.

Идея простыми словами. На примерах, которые модель «видела», она обычно ведёт себя увереннее, чем на новых: выше уверенность, ниже ошибка. Сравнивая поведение на «своих» и «чужих» объектах, можно с заметной точностью угадать, входил ли объект в обучение.

Почему это нарушение приватности: сам факт участия в обучении бывает чувствительным. «Этот хост был в выборке инцидентов», «этот пользователь – в наборе скомпрометированных учётки» – это уже раскрытие, даже без восстановления самой записи.



LLM-memorization как частный случай

17 / 58

ЧАСТЬ 3А · ПРИВАТНОСТЬ

Большие языковые модели делают запоминание особенно наглядным

Запоминание – общий эффект, но в больших языковых моделях (**из L16**) он проявляется ярче всего: при подходящем запросе модель способна **дословно воспроизвести фрагменты обучающего корпуса** – ключи, адреса, куски внутренних документов, персональные данные, если они там были.

Почему в LLM это заметнее

- огромная ёмкость и объём обучающего текста
- редкие строки запоминаются почти буквально
- генерация позволяет «вытащить» текст наружу

Что это значит для ИБ

- не дообучать на сырых секретах и логах «как есть»
- фильтровать чувствительное до обучения
- контролировать вывод (human-in-the-loop, L16)



Частая ошибка: «задача не персональная»

Приватность сводят к персональным данным людей – и упускают служебные сведения

ЧАСТАЯ ОШИБКА

«У нас же не персональные данные, а сетевые логи и события – значит, про приватность можно не думать».

Под «приватностью» ошибочно понимают только ФИО, телефоны и адреса – и не замечают остального чувствительного.

ПОЧЕМУ ЭТО НЕВЕРНО

В данных безопасности служебные сведения часто чувствительнее, чем «классические» персональные:

- внутренние IP, имена хостов и учётных записей раскрывают топологию и устройство сети;
- сигнатуры, пороги и правила детектирования – это карта того, что и как вы умеете ловить;
- сам факт, что объект попал в выборку инцидентов, – уже разглашение (membership inference, сл. 16).



Что важно унести из первого под-блока, прежде чем перейти к мерам

ЧТО МЫ РАЗОБРАЛИ В А.1

- Приватность – отдельное свойство ML-системы, не сводимое к качеству; в ИБ оно охватывает и служебные сведения, а не только персональные данные.
- Модель запоминает отдельные обучающие примеры (memorization), и метрики этого не показывают.
- Каналы утечки шире датасета: логи, отчёты, опубликованные примеры, embeddings, артефакты обучения, поведение модели и метаданные.
- Даже без восстановления записи возможен membership inference – раскрытие самого факта участия объекта в обучении.

Дальше – А.2: какими мерами этот риск снижают.



ЧАСТЬ 3 · БЛОК А · А.2

Меры снижения риска

Риски разобраны. Теперь – что с ними делать: от организационной дисциплины к техническим подходам. Меры выстраиваются слоями, а не выбираются «или-или».

A.1 Риски разобрано

A.2 Меры сейчас здесь

A.3 Trade-off далее



Базовые меры: с них начинают

21 / 58

ЧАСТЬ 3А · ПРИВАТНОСТЬ

Организационная дисциплина закрывает большую часть риска до всякой математики

Прежде чем думать о сложных privacy-методах, нужно навести порядок в обращении с данными. **Эти меры дешёвы, не требуют изменения модели и снимают самые частые утечки** – те, что идут через артефакты и доступ, а не через саму модель.

Минимизация данных

собирать и хранить только те поля, что реально нужны модели

Обезличивание

удалять/маскировать прямые идентификаторы – но с оговоркой (сл. 22)

Контроль доступа

кто и к каким данным, артефактам и эмбедингам имеет доступ

Ограничение хранения

сроки жизни датасетов, чекпоинтов, логов; удаление по графику

Журналирование

кто обращался к данным и модели – для аудита и расследований

Дисциплина публикации

проверка примеров и артефактов перед выходом наружу



Частая ошибка: «обезличили – значит безопасно»

Удаление прямых идентификаторов снижает риск, но не обнуляет его

⚠ ЧАСТАЯ ОШИБКА

«Мы убрали имена и IP – данные обезличены, дальше можно не осторожничать».

Обезличивание приравняют к полному устранению риска – и перестают контролировать данные и артефакты.

ПОЧЕМУ ЭТО НЕВЕРНО

Реидентификация остаётся возможной – обезличивание ослабляет, но не снимает риск:

- квазиидентификаторы (порт, объём трафика, время, редкая комбинация признаков) вместе указывают на объект однозначно;
- связывание с внешними данными восстанавливает личность/узел даже без прямых идентификаторов;
- модель всё равно может запоминать и раскрывать обезличенные, но уникальные записи (сл. 12, 16).



Privacy-preserving подходы: общая идея

23 / 58

ЧАСТЬ 3А · ПРИВАТНОСТЬ

Технические меры объединяет один принцип – ограничить вклад отдельного объекта

За разными privacy-методами стоит одна мысль: **результат не должен зависеть от любого отдельного объекта обучающего набора настолько, чтобы по результату этот объект можно было распознать.** Достигают этого, ограничивая объём информации, которую модель «забирает» из каждой записи.

Агрегирование

работать со статистикой по группам, а не с отдельными записями

Регуляризация

ограничивать ёмкость и переобучение – меньше места для запоминания

Ограничение информации

урезать то, что модель/артефакт раскрывают о входе

Добавление шума

вносить контролируемый шум, маскирующий вклад одной записи

Эти идеи не взаимоисключающие. *Differential privacy (сл. 24) формализует именно последнюю – добавление шума с измеримой гарантией.*



Гарантия: присутствие одного объекта почти не влияет на результат

ОПРЕДЕЛЕНИЕ

Differential privacy (на уровне идеи)

Свойство алгоритма: его результат меняется лишь незначительно при добавлении или удалении любого одного объекта. Тогда по результату нельзя уверенно сказать, был ли конкретный объект в данных.

Интуиция. Представьте два набора данных, отличающихся ровно одной записью. Если выходы алгоритма на них практически неразличимы, то наличие или отсутствие этой записи «теряется» в результате. Достигается это добавлением калиброванного шума – за приватность платят небольшим снижением точности.

В рамках курса – только интуиция. Формальное определение (ϵ , δ), механизмы Лапласа/Гаусса и бюджет приватности мы не разбираем – важно понимать смысл и цену гарантии.



Federated и split learning одной позицией

Подходы, перераспределяющие данные между сторонами, – и их ограничения

Идея этих подходов – **не свозить исходные данные в одно место**. Данные остаются у владельцев, а наружу выходит только то, что нужно для совместного обучения. Это снижает риск утечки централизованного датасета, но не делает приватность бесплатной.

Federated learning

Модель обучается у каждой стороны локально; в центр отправляют только обновления параметров, а не данные.

Split learning

Сеть «разрезана»: первые слои считает владелец данных, дальше – другая сторона по промежуточным представлениям.

ОГРАНИЧЕНИЯ (важно)

обновления и промежуточные представления тоже могут утекать (из них восстанавливают данные); требуется доверие к агрегатору и защищённый обмен; не отменяют memorization и membership inference. *В курсе – без углубления.*



Trade-off: полезность против приватности

Усиление приватности почти всегда стоит части качества – это осознанный выбор

Чем сильнее мы ограничиваем вклад отдельных записей (больше шума, агрегирования, регуляризации), тем выше приватность – и тем ниже точность и детальность модели. **Идеальной точки нет: её выбирают под задачу и цену ошибок (из L04).**

Больше полезности

Больше приватности

меньше приватности

*точка выбирается
под задачу*

меньше полезности

Практически: уровень приватности – это проектное решение, которое фиксируют явно (что пожертвовали в качестве и ради какой защиты), а не «настройка по умолчанию». Этот выбор идёт в reliability note.



Документирование рисков и ограничений

Меры работают, только если они зафиксированы письменно – мост к итоговой оценке

Любая privacy-мера бесполезна, если о ней знает один человек и нигде не записано. **Риски, принятые меры и остаточные ограничения должны быть частью документации модели** – иначе при передаче, аудите или инциденте их невозможно проверить.

Какие данные использованы

источники, чувствительные поля, что обезличено

Какие меры приняты

минимизация, доступ, хранение, privacy-методы и их параметры

Остаточные риски

что мерами не закрыто (memorization, реидентификация)

Режим обращения с артефактами

доступ и хранение весов, эмбедингов, логов

→ Это и есть вход в Блок В: приватность становится одним из разделов итогового *reliability/security note*.



Чем закрываем риск (А.2) и какой ценой (А.3) – итог всего Блока А

ЧТО МЫ РАЗОБРАЛИ В А.2-А.3

- Меры выстраиваются слоями: сначала организационная дисциплина (минимизация, доступ, хранение, журналирование), потом технические подходы.
- Обезличивание снижает, но не обнуляет риск – реидентификация по квазиидентификаторам остаётся возможной.
- Privacy-preserving подходы ограничивают вклад одного объекта; differential privacy формализует это интуитивно – без математики в рамках курса.
- Federated и split learning перераспределяют данные, но не отменяют memorization; за приватность всегда платят полезностью – выбор фиксируют в документации.

На этом Блок А завершён. Дальше – Блок В: сборка всего курса в итоговый reliability/security note.



ЧАСТЬ 3 · БЛОК В

Итоговая оценка надёжности

Вторая половина лекции. Теперь соберём весь курс в один документ – reliability/security note: можно ли доверять модели, в каких пределах и при каких допущениях.



Структурированный итог: можно ли доверять модели и в каких границах

ОПРЕДЕЛЕНИЕ

Reliability / security note

Краткий структурированный документ, который сводит воедино качество, устойчивость, безопасность и приватность модели и явно фиксирует границы её применимости и условия доверенного использования.

Зачем отдельный документ. Знания о модели разбросаны: метрики – у одного, stress-тесты – у другого, риски приватности – у третьего. Note собирает их в одном месте, на одном языке, так что решение «внедрять или нет» принимается осознанно, а не по одной цифре accuracy.

Не путать с отчётом о качестве. Отчёт о метриках отвечает «насколько модель точна». Reliability note отвечает «при каких условиях ей можно доверять» – и включает то, о чём метрики молчат.



Структура note: восемь разделов

31 / 58

ЧАСТЬ 3В · ОЦЕНКА НАДЁЖНОСТИ

Каждый раздел возвращается к конкретной лекции курса – это сборка всего пройденного

Note – это формальный артефакт. Минимальный каркас из восьми разделов; ниже у каждого указана лекция-источник.

1

Задача и сценарий

из L03

2

Данные и ограничения

из L02·L10·L11·L12

3

Метрики и протокол

из L04·L05

4

Интерпретация и ошибки

из L09

5

Устойчивость и stress

из L17

6

Adversarial-риски

из L18

7

Poisoning / supply-chain

из L19

8

Приватность данных

из Блока А

Следующие слайды раскрывают каждый раздел по очереди, заканчивая сборкой на CIC-IDS-2018.



Раздел 1 – задача и сценарий

32 / 58

ЧАСТЬ 3В · ОЦЕНКА НАДЁЖНОСТИ

С чего начинается note: что именно модель решает и как используется

РАЗДЕЛ 1 ИЗ 8 · из L03

Надёжность нельзя оценивать в вакууме – только относительно задачи. **Первый раздел note фиксирует постановку (из L03): что предсказываем, на каком объекте, в каком режиме модель работает.** Без этого все метрики и риски ниже теряют смысл – непонятно, относительно чего они «хорошие» или «опасные».

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

Тип задачи и объект: что классифицируем/детектируем и что считается одним объектом (flow, сессия, хост).

Режим использования: автоблокировка, триаж или помощь аналитику – от этого зависит цена ошибок (линия «модель как компонент системы», L03→L07→L20).

Допущения и baseline: с чем сравниваем (baseline из L03) и при каких условиях вывод о надёжности вообще действителен.



Откуда данные, насколько они репрезентативны и что про них известно плохого

РАЗДЕЛ 2 ИЗ 8 · из L02·L10·L11·L12

Качество модели не выше качества данных. Этот раздел фиксирует происхождение и ограничения данных: как смотреть на датасет (L02), как построен воспроизводимый конвейер (L10), известные ограничения публичных ИБ-датасетов (L11) и временную структуру (L12). Без честного описания данных вывод о надёжности необоснован.

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Происхождение и репрезентативность:** источники, период сбора, покрытие классов атак, перекосы выборки.
- **Известные ограничения:** артефакты публичных датасетов (NSL-KDD, CIC-IDS-2018), устаревание, смещения (L11).
- **Конвейер и время:** воспроизводимость препроцессинга (L10), временная структура и риск устаревания (L12).



Раздел 3 – метрики и протокол оценки

34 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Какими метриками мерили, под какую цену ошибок и по какому протоколу

РАЗДЕЛ 3 ИЗ 8 · из L04-L05

Цифра без протокола ничего не значит. Раздел фиксирует не только сами метрики (L04), но и то, как они получены: схему валидации и защиту от утечки данных (L05). Метрики выбирают под цену ошибок задачи, а не «accuracy по умолчанию».

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Метрики под цену ошибок:** precision/recall, PR-AUC, цена FP против FN в выбранном режиме (L04).
- **Протокол валидации:** holdout / CV / time-based / group split; почему случайный split на ИБ-данных опасен (L05).
- **Контроль утечки:** leakage по target, времени, группе исключён; результат воспроизводим (L05).



Раздел 4 – интерпретация и анализ ошибок

35 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Понятно ли, почему модель решает так, и где концентрируются её ошибки

РАЗДЕЛ 4 ИЗ 8 · из L09

Доверие требует объяснимости. Раздел фиксирует, что известно о логике модели и структуре её ошибок (L09): какие признаки важны, где модель систематически ошибается, нет ли проблемных срезов. Это же помогает поймать скрытую утечку, проявляющуюся как «слишком хорошие» признаки.

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Глобальная и локальная интерпретация:** важность признаков, объяснение отдельных решений (L09).
- **Анализ ошибок и срезов:** где концентрируются ошибки, slice analysis по чувствительным группам (L09).
- **Связь с leakage:** подозрительно «всесильные» признаки как сигнал утечки (линия L05→L09).



Что происходит с моделью, когда данные меняются сами (без противника)

РАЗДЕЛ 5 ИЗ 8 · из L17

Среда меняется – модель должна выдерживать. Раздел фиксирует поведение под неблагоприятными, но не враждебными изменениями (L17): шум, выбросы, сдвиг распределений, OOD, concept drift. Здесь же – что произойдёт с ошибками и порогом, когда среда «уедет» (линия «цена ошибок и порог»).

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Виды сдвига:** covariate/label shift, OOD-входы, постепенный concept drift источников данных (L17).
- **Результаты stress-тестов:** как падает качество при разумных возмущениях; где порог теряет смысл.
- **Меры устойчивости:** регуляризация, augmentation, план переобучения и мониторинга drift (L17).



Раздел 6 – adversarial-риски

37 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Что может сделать противник, целенаправленно подбирая вход модели

РАЗДЕЛ 6 ИЗ 8 · из L18

Теперь – не природа, а противник. Раздел фиксирует модель угроз для ML-компонента и риски уклонения (L18): кто атакует, что знает и какими возмущениями входа способен обмануть модель. Threat modeling для ML (из L18) применяется здесь без переопределения.

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Модель угроз:** цели атакующего и его доступ – white / gray / black-box (threat modeling, L18).
- **Риски уклонения:** evasion через возмущения входа (FGSM, PGD), перенос атак (transferability) (L18).
- **Меры снижения:** feature hardening, ансамбли проверок, fallback-механизмы (L18).



Раздел 7 – poisoning и supply-chain

38 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Что, если противник испортил обучающие данные или артефакты

РАЗДЕЛ 7 из 8 · из L19

Атака может быть и до инференса. Если раздел 6 – про противника на входе модели, то этот – про противника на обучении и в цепочке поставки (L19): отравление данных, скрытые бэкдоры, скомпрометированные зависимости. Это завершает модель угроз для ML (линия L17→L18→L19→L20).

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Poisoning и backdoor:** целевое искажение обучающих данных, скрытые триггеры в модели (L19).
- **Supply-chain риски:** предобученные веса, сторонние датасеты, библиотеки и зависимости (L19).
- **Меры контроля:** происхождение данных и артефактов, проверка целостности, изоляция сборки (L19).



Раздел 8 – приватность данных

39 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Сводим выводы первой половины лекции в один раздел note

РАЗДЕЛ 8 из 8 · из Блока А этой лекции

Приватность – равноправный раздел надёжности. Здесь собираются выводы Блока А: что модель может запоминать, по каким каналам утекать, какие меры приняты и какой ценой. Этот раздел отличает reliability/security note от обычного отчёта о качестве.

ЧТО ЗАФИКСИРОВАТЬ В РАЗДЕЛЕ

- **Риски запоминания:** memorization, membership inference, восстановление из артефактов и embeddings.
- **Принятые меры:** минимизация, доступ, хранение; privacy-методы и их параметры (если применялись).
- **Остаточный риск и trade-off:** что не закрыто и какой ценой в качестве куплена приватность.



Финальный раздел note: где модель применять можно и в каком режиме, а где – нельзя

ЗАВЕРШАЮЩИЙ РАЗДЕЛ NOTE · сводит воедино все предыдущие

Все предыдущие разделы сходятся здесь в одно явное утверждение: **при каких условиях выводам note можно доверять и где модель использовать запрещено**. Это защищает от применения «не по назначению» – самой частой причины тихого отказа ML в эксплуатации.

Условия применимости

- тот же тип данных и сценарий, что при оценке
- заявленный режим (блокировка / триаж / помощь)
- мониторинг drift и план переобучения активны

Где применять нельзя

- другой источник/распределение данных
- более высокая цена ошибки, чем заложена
- полная автоматизация там, где нужен человек



ИБ-кейс: собираем note на CIC-IDS-2018

41 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Сквозной датасет курса как пример итоговой сборки – все разделы вместе

ИБ - К Е Й С · детектор подозрительного трафика на CIC-IDS-2018

1 · Задача	детект атак во flow-записях; режим – триаж для аналитика
2 · Данные	~16 млн flow, 80 признаков; известные смещения и устаревание датасета
3 · Метрики	PR-AUC и recall по атакам; time-based split, leakage исключена
4 · Интерпретация	важные признаки правдоподобны; ошибки концентрируются на редких атаках
5 · Устойчивость	качество падает при смене источника трафика (drift) – нужен мониторинг
6 · Adversarial	возможна evasion подгонкой признаков потока; добавлены проверки
7 · Poisoning	данные публичные → риск supply-chain; зафиксировано происхождение
8 · Приватность	во flow есть внутренние адреса; доступ и хранение ограничены

Вывод note: модель пригодна как помощник аналитика на трафике того же профиля, с мониторингом drift и ограниченным доступом к данным; не пригодна для автоблокировки и для иного источника трафика.



Доверие как условное свойство

42 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Главный принцип итоговой оценки: доверие всегда «при условиях», а не абсолютно

Reliability note не выдаёт вердикт «модель надёжна / ненадёжна». Он формулирует доверие как условное: модели можно доверять в таких-то границах, при таких-то допущениях, в таком-то режиме — и нельзя за их пределами. Это честнее и практичнее бинарного «работает / не работает».

Доверие(модель) = **надёжна** **ПРИ УСЛОВИИ** { сценарий из L03 · данные того же профиля · режим · мониторинг drift · принятые меры приватности }

Практический смысл: снять любое из условий — значит выйти за границы, где оценка надёжности действительна. Поэтому условия фиксируются письменно и проверяются перед каждым новым применением модели.



Надёжность воспринимают как бинарный флаг вместо набора условий

⚠ ЧАСТАЯ ОШИБКА

«Модель прошла проверку – значит, она надёжна и ей можно доверять. Точка».

Надёжность сводят к бинарному «работает / не работает» и забывают про условия, в которых этот вывод верен.

ПОЧЕМУ ЭТО НЕВЕРНО

Доверие условно (сл. 42) – снятие условий меняет вывод, а бинарный флаг этого не отражает:

- «надёжная» модель перестаёт быть таковой при смене источника данных или режима использования;
- флаг «работает» скрывает, что под drift, атакой или на новых данных поведение не проверялось;
- честное «надёжна при условиях X» полезнее ложной уверенности – оно говорит, когда остановиться.



Частая ошибка: четыре измерения порознь

44 / 58

ЧАСТЬ 3В · НАДЁЖНОСТЬ

Качество, устойчивость, безопасность и приватность оценивают по отдельности

⚠ ЧАСТАЯ ОШИБКА

«Метрики посчитал, stress-тесты прогнал, приватность проверил – всё по отдельности готово».

Измерения проверяют изолированно и не собирают в единый вывод – note подменяют набором несвязанных отчётов.

ПОЧЕМУ ЭТО НЕВЕРНО: ИЗМЕРЕНИЯ ВЗАИМОДЕЙСТВУЮТ

Приватность × качество

усиление приватности (шум, агрегирование) снижает точность – это один баланс, а не два

Устойчивость × ошибки

под drift меняется цена ошибок и осмысленность порога – нельзя смотреть отдельно

Безопасность × данные

evasion и poisoning бьют именно по данным и признакам, оценённым в других разделах

Всё × сценарий

режим использования (L03) задаёт, какие измерения и насколько критичны



Что унести из Блока В – и чем завершается вся Часть 3

ЧТО МЫ РАЗОБРАЛИ В БЛОКЕ В

- Reliability/security note – итоговый документ, сводящий качество, устойчивость, безопасность и приватность в один вывод о доверии.
- Каркас note – восемь разделов, каждый возвращается к своей лекции курса (L03·L04·L05·L09·L17·L18·L19 и приватность из Блока А).
- Сборка на сквозном датасете (CIC-IDS-2018) даёт явный вывод: где модель применима, а где – нет.
- Доверие условно: модель надёжна при зафиксированных допущениях, а не абсолютно; снятие условия выводит за границы оценки.

На этом Часть 3 завершена. Дальше – Часть 4: как это выглядит в реальных задачах ИБ.



ЧАСТЬ 4 · СВЯЗКИ С ПРАКТИКОЙ ИБ

Как это выглядит в реальных задачах ИБ

Теория приватности и итоговой оценки разобрана. Теперь – что в ней специфично именно для данных безопасности и какие ловушки подстерегают на практике.



Почему в безопасности почти любые данные требуют контроля и минимизации

Данные безопасности почти всегда содержат служебно значимые сведения – **даже когда в них нет «классических» персональных данных**. Поэтому здесь по умолчанию действует режим минимизации и контроля доступа, а не презумпция «это просто технические логи».

Топология и инфраструктура

внутренние IP, имена хостов и сегментов, схема сети

Учётные записи и идентичности

логины, сервисные аккаунты, привилегии, принадлежность

Защитные механизмы

сигнатуры, пороги, правила детектирования – карта ваших возможностей

Инцидентный контекст

что, когда и где сработало; какие активы затронуты

Вывод: «внутреннее» не значит «безопасное» – раскрытие такой информации помогает атакующему даже без персональных данных.



Текстовые описания инцидентов – богатый и недооценённый источник утечки

ИБ-КЕЙС

Модель на отчётах об инцидентах

Команда дообучила языковую модель на архиве инцидентных отчётов, чтобы помогать аналитикам составлять сводки. В отчётах – **имена сотрудников, внутренние хосты, фрагменты конфигураций, детали реагирования и индикаторы компрометации**. Всё это попало в обучающий корпус «как есть», без фильтрации.

Риск: при свободных запросах модель воспроизводит фрагменты конкретных отчётов – раскрывая, кто, когда и как реагировал на реальные инциденты. Это LLM-memorization (сл. 17) на чувствительном корпусе; метрики качества сводок его не показывали.



Из опубликованных весов, примеров и эмбедингов восстанавливают закрытое

ИБ-КЕЙС

«Поделились моделью для воспроизводимости»

Чтобы коллеги могли воспроизвести результат, команда выложила обученную модель, набор «репрезентативных» примеров и индекс эмбедингов. Казалось, что сами данные не публикуются – только артефакты. Но **из эмбедингов и поведения модели восстанавливаются исходные записи и факт их участия в обучении.**

Риск: опубликованные артефакты – это производные данных (сл. 14-15). Внешний исследователь проводит membership inference (сл. 16) и инверсию эмбедингов, получая закрытые сведения, которые «напрямую» не выкладывались.



Ловушки, специфичные для ИБ

50 / 58

ЧАСТЬ 4 · СВЯЗКИ С ИБ

Где именно в задачах безопасности чаще всего ошибаются с приватностью

⚠ ОБЩИЙ ПАТТЕРН

Риск утечки в ИБ почти всегда идёт не из самого датасета, а из производных артефактов и из ложного ощущения, что «внутренние технические данные не чувствительны».

Артефакты важнее датасета

контролируют исходные данные, но свободно делятся весами, примерами, эмбедингами

«Внутреннее = безопасное»

служебные сведения раскрывают, считая их «просто техникой»

Обезличивание как индульгенция

удалили IP и логины – и сочли задачу закрытой (реидентификация остаётся)

Нет границ применимости

модель уходит в другой сценарий, где её приватность не оценивалась



Почему обращение с данными вообще регулируется – без правового анализа

Обращение с персональными и чувствительными данными регулируется законом и внутренними политиками. **Для инженера это означает простое правило: технические privacy-меры существуют не «для галочки», а потому что у обращения с данными есть внешние требования.** Конкретные нормы зависят от юрисдикции и организации.

ФЗ-152

о персональных данных (РФ)

GDPR

защита данных (ЕС)

Регулирование ИИ

формирующиеся требования к ИИ-системам

Граница курса: мы не проводим правовой анализ и не разбираем нормы детально – это отдельная дисциплина. Задача инженера: знать, что требования есть, и закладывать privacy-меры заранее, а юридическую проверку оставлять профильным специалистам.



Note – это обязательный шаг go / no-go, а не финальная формальность

Note составляют не «для архива», а как условие допуска модели в эксплуатацию. Перед внедрением он отвечает на главный вопрос: можно ли запускать модель в этом сценарии – и если да, то с какими ограничениями и под каким контролем.

GO

Внедрять

условия выполнимы, остаточные риски приемлемы, режим и мониторинг определены

GO с условиями

Внедрять ограниченно

только в заявленном режиме, с мониторингом drift и ограниченным доступом к данным

NO-GO

Не внедрять

критичные риски не закрыты или границы применимости не выполняются

Ключевая мысль: внедрение без note создаёт ложное чувство надёжности; именно note превращает «модель готова» в проверяемое решение.



1

Качество $\neq$ допустимость

хорошие метрики не означают, что модель можно внедрять; надёжность шире точности.

2

Модель запоминает данные

memorization и membership inference – реальные риски, невидимые в метриках.

3

Утечка шире датасета

раскрытие идёт через логи, примеры, embeddings, артефакты и поведение модели.

4

Обезличивание $\neq$ безопасность

реидентификация по квазиидентификаторам остаётся возможной.



5

Privacy всегда имеет цену

DP, federated/split – идеи со своими ограничениями; за приватность платят полезностью.

6

Note связывает четыре измерения

качество + устойчивость + безопасность + приватность собираются в один вывод о доверии.

7

Доверие условно

модель надёжна при зафиксированных допущениях и в заявленном режиме, а не абсолютно.



Завершающая лекция замыкает три сквозные линии курса

L20 – финал курса. Три сквозные линии сходятся именно здесь, в итоговой оценке надёжности:

Модель как компонент системы

L03 → L07 → L16 → L18 → L20

завершается итоговым reliability/security note

Цена ошибок и порог

L04 → L07 → L09 → L17 → L20

фиксируется в note под сценарий и режим

Threat modeling для ML

L17 → L18 → L19 → L20

замыкается privacy-рисками – четвёртый угол модели угроз



ОБЯЗАТЕЛЬНОЕ

Hastie, Tibshirani, Friedman. The Elements of Statistical Learning

Гл. 7 «Model Assessment and Selection» – методическая основа того, как вообще оценивать модель (опора для reliability note).

Shokri et al. Membership Inference Attacks Against ML Models (2017)

Базовая статья о membership inference – на уровне идеи (раздел 8 note, сл. 16).

Dwork, Roth. The Algorithmic Foundations of Differential Privacy (2014)

Введение в DP; в рамках курса – только интуиция (сл. 24), главы 1-2 для общего смысла.

Carlini et al. Extracting Training Data from Large Language Models (2021)

LLM-memorization как частный случай (сл. 17): как из модели достают обучающий текст.



Источники для углубления (2/2)

57 / 58

ЧАСТЬ 6 · ИСТОЧНИКИ

Часть 6 · Дополнительно и практика

ДОПОЛНИТЕЛЬНО

McMahan et al. Communication-Efficient Learning... (Federated, 2017)

идея federated learning одной позицией (сл. 25), без углубления.

Abadi et al. Deep Learning with Differential Privacy (2016)

как DP применяют при обучении – для интересующихся, за рамками курса.

ПРАКТИКА И ДАННЫЕ

Документация Opacus (PyTorch) / TensorFlow Privacy

практические tutoriales по обучению с differential privacy.

CIC-IDS-2018 – сквозной датасет курса

площадка для итогового проекта: соберите reliability note на нём.



Часть 7 · Ключевые термины лекции

Приватность ML-системы – свойство не раскрывать сведения об отдельных обучающих объектах

Membership inference – определение, был ли объект в обучающем наборе, по поведению модели

Квазиидентификатор – признак, который в сочетании с другими указывает на объект

Обезличивание – удаление/маскирование прямых идентификаторов

Federated learning – обучение без централизации данных; в центр идут обновления

Embedding – плотное векторное представление объекта; тоже данные

Reliability/security note – итоговый документ о доверии к модели и её границах

Запоминание (memorization) – удержание моделью следов конкретных обучающих примеров

Реидентификация – восстановление личности/узла из обезличенных данных

Минимизация данных – сбор и хранение только реально необходимых полей

Differential privacy – гарантия: один объект почти не влияет на результат (интуитивно)

Split learning – сеть разрезана между сторонами по промежуточным представлениям

Trade-off приватность/польза – усиление приватности снижает точность – выбор под задачу

Условное доверие – надёжность при зафиксированных допущениях, а не абсолютно